KMUTT | DEPARTMENT OF COMPUTER ENGINEERING

CPE 334 Introduction to Software Engineering in the Age of AI Agents (Semester 1/2026)

Pollipop

University Review, Feedback, and Survey System

Project Deliverable 1: Engineering Baseline and Working Sprint 1

Course & Term:	CPE 334 (Semester 1/2026) | Due: 8 November 2026, 23:59 (80 Points / 8% Grade)
Assigned Theme:	Theme 10: Review, Feedback, and Survey System
GitHub Repository:	`https://github.com/phatthidawadi/pollipop` (Public per R-12)
Submitted Release Branch:	`sprint-1-staging` (Commit `f377e5e` / Tag `v1.0.0-sprint1`)
Student 1 (Author / Lead):	ภัทร์ธิดาวดี อุ่นคำ (Phatthidawadi Aunkham) — Student ID: **67070505225** (GitHub: `@phatthidawadi`)
Student 2 (Author / Lead):	ปทิตญา แก้ววิเชียร (Patitaya Kaewwichian) — Student ID: **67070505220** (GitHub: `@lmaybelgracel`)

Master Evidence Index & Navigation Table (Protocol Section 4.3)

This master navigation index outlines all engineering artifacts and verification evidence required under the CPE 334 Deliverable 1 Protocol (Parts A through F):

Part	Heading / Requirement Scope	Associated Stable IDs	Artifact Source & Execution Evidence Location
Part A	Software Requirements Specification (SRS)	FR-01..16, BR-01..13, NFR-01..05	`docs/srs.md` (Complete product scope, actors, decisions)
Part B	Feature Inventory & Traceability Matrix	S-01, F-01..F-09	`docs/features.md`, `docs/traceability.md` (Full requirements mapping)
Part C	System-Level Software Design Specification (SDS)	Three-Tier Architecture, ERD	`docs/system-sds.md` (Stack, ERD, Security, Role Matrix, GCP Plan)
Part D	Three-Sprint Plan & Pair Allocation	Sprints 1, 2, 3	`docs/sprints/plan.md` (Vertical slice rationale, 10 balanced issues)
Part E	Sprint 1 Master Engineering Contracts	AC-01..38, TEST-01..40	`docs/sprints/sprint-1/contracts.md` (Feature design, STS, DoD)

Part	Heading / Requirement Scope	Associated Stable IDs	Artifact Source & Execution Evidence Location
Part F	Working Sprint 1 Verification & Evidence	46 Tests (100% Pass)	`docs/sprints/sprint-1/verification.md` (Screenshots, logs, PR reviews)

Part A: Software Requirements Specification (SRS)

> **Suggested Artifact:** `docs/srs.md` | **Weight:** 10 Points | Demonstrates: Stakeholders, Context, Actors, Product Scope, Numbered FR/BR/NFR, Assumptions & Decisions.

1. Stakeholder Problem & System Context

1.1 Stakeholder Problem

Within university environments, academic departments, course instructors, administrative officers, and student club coordinators (Survey Owners) routinely conduct evaluations regarding course delivery, campus dining, library resources, and university Wi-Fi infrastructure. Existing paper forms or off-the-shelf consumer tools have three fundamental engineering failures:

- **Uncontrolled Duplicate Submissions & Identity Leakage:** Generic tools cannot reliably enforce single-submission limits without exposing respondent identities in evaluation results.
- **Absence of Role-Based & Institutional Access Control:** Consumer tools lack institutional boundary enforcement. One instructor can accidentally view or alter another instructor's evaluations.
- **Data Corruption from Post-Publish Alterations:** Permitting survey questions or options to be edited after responses have arrived invalidates historical submissions and corrupts aggregate metrics.

1.2 Chosen Domain Context: Pollipop

Pollipop is a cloud-ready, three-tier web application specifically engineered for university course evaluations and campus feedback. The system manages the entire survey lifecycle: structured survey authoring (Single Choice 2–10 options, Rating 1–5), survey state progression (`DRAFT` → `PUBLISHED` → `CLOSED`), authenticated single-submission response collection inside atomic database transactions, and real-time server-side aggregate calculation.

2. Actors and Responsibilities

Actor / Role	Role Code	Allowed Operations	Explicitly Forbidden Operations
Survey Owner (Instructor / Staff)	`OWNER`	- Create surveys in `DRAFT` status. - Transition survey state to `PUBLISHED` or `CLOSED`. - Inspect real-time server-computed aggregate summaries of own surveys.	- **Forbidden:** Accessing or altering surveys owned by other owners (`403 Forbidden`). - **Forbidden:** Submitting responses to any survey (`403 Forbidden`).

Actor / Role	Role Code	Allowed Operations	Explicitly Forbidden Operations
Survey Respondent (Student / Campus Member)	`RESPONDENT`	- View open (`PUBLISHED`) surveys with completion status. - Submit a validated response exactly once per survey. - Review own submitted answers in `IDENTIFIED` mode.	- **Forbidden:** Creating, publishing, or closing surveys (`403 Forbidden`). - **Forbidden:** Viewing `DRAFT` surveys (`404 Not Found`). - **Forbidden:** Viewing aggregate summary analytics (`403 Forbidden`). - **Forbidden:** Viewing other students' answers (`403 Forbidden`).

3. Numbered Functional Requirements (FR)

FR ID	Observable Requirement Behavior	Sprint
FR-01	**User Login & Session Creation:** Authenticate via email/password, verify bcrypt hash, set HTTP-only `pollipop_sid` cookie.	Sprint 1
FR-02	**Current User Profile & Logout:** Retrieve profile (`GET /api/auth/me`) and destroy session (`POST /api/auth/logout`) with cache invalidation.	Sprint 1
FR-03	**Health & Readiness Probes:** `GET /api/health` (liveness) and `GET /api/ready` (readiness with database `SELECT 1`).	Sprint 1
FR-04	**Create Draft Survey:** `OWNER` creates survey with title, description, mode (`IDENTIFIED`), and questions in `DRAFT` status.	Sprint 1
FR-05	**Sprint 1 Question Types:** Accept `SINGLE_CHOICE` (2–10 options) and `RATING` (1–5) questions with `required` flag.	Sprint 1
FR-06	**Publish Survey:** `OWNER` transitions survey from `DRAFT` to `PUBLISHED` (making it active for respondents).	Sprint 1
FR-07	**List Surveys by Role:** `OWNER` sees own surveys; `RESPONDENT` sees `PUBLISHED` surveys with `answered` and `responseId` .	Sprint 1
FR-08	**Submit Validated Response:** `RESPONDENT` submits answers inside an atomic database transaction.	Sprint 1
FR-09	**View Own Submitted Response:** In `IDENTIFIED` mode, `RESPONDENT` inspects submitted answers via `GET /api/responses/:id` .	Sprint 1
FR-10	**View Survey Aggregate Summary:** `OWNER` retrieves server-calculated statistics (counts, percentages, mean rating).	Sprint 1
FR-11	**Edit Draft Survey:** `OWNER` updates title, description, or questions while in `DRAFT` status.	Sprint 2
FR-12	**Close Survey & Expiration:** Manual close (`POST /api/surveys/:id/close`) or scheduled closing (`closesAt`).	Sprint 1 / 2

FR ID	Observable Requirement Behavior	Sprint
FR-13	**Anonymous Survey Mode:** Decouple participation tracking from answer storage (`respondentId = null`).	Sprint 2
FR-14	**Department Eligibility:** Restrict survey answering to students matching `targetDepartment` .	Sprint 2
FR-15	**Extended Question Types:** Multi-select (`MULTIPLE_CHOICE`) and open feedback (`SHORT_TEXT`).	Sprint 2
FR-16	**Export Survey Results:** Download summary analytics and anonymized responses as CSV files.	Sprint 3

4. Numbered Business Rules (BR)

BR ID	Domain Rule Description	Enforced Layer
BR-01	**Single Submission per Respondent:** Duplicate attempts return `409 Conflict (ALREADY_SUBMITTED)` backed by DB unique constraint `(surveyId, userId)` on `SurveyParticipation` .	Application & DB
BR-02	**Responses Allowed Only on Published Surveys:** Answering `DRAFT` returns `404 Not Found` ; answering `CLOSED` returns `409 Conflict (SURVEY_NOT_OPEN)` .	Application
BR-03	**One-Way Survey Lifecycle State Machine:** States progress `DRAFT` → `PUBLISHED` → `CLOSED` . Reversing state returns `409 Conflict (INVALID_STATE_TRANSITION)` .	Application
BR-04	**Survey Ownership Isolation:** `OWNER` cannot access, edit, publish, close, or inspect summaries of surveys owned by others (`403 Forbidden`).	Application
BR-05	**Role Segregation:** `RESPONDENT` cannot author/publish surveys or view summaries; `OWNER` cannot submit responses (`403 Forbidden`).	Application
BR-06	**Cross-Response Privacy:** `RESPONDENT` can only view own submitted answers; inspecting another user's answers returns `403 Forbidden` .	Application
BR-07	**Draft Survey Visibility Restriction:** `RESPONDENT` cannot view or retrieve `DRAFT` surveys (`404 Not Found`).	Application
BR-08	**Question & Option Structural Constraints:** Survey must have 1–50 questions. `SINGLE_CHOICE` must have 2–10 non-empty options.	Application
BR-09	**Answer Completeness & Validity:** Required questions must be answered. Options must belong to the question. Rating must be 1–5. Optional questions may be omitted.	Application & DB
BR-10	**Server-Side Aggregate Accuracy:** Statistics computed server-side to 2 decimal places. Handles zero responses without division by zero.	Application
BR-11	**Immutability After Publication:** Modifying questions/options after publication is forbidden (`409 Conflict`).	Application

BR ID	Domain Rule Description	Enforced Layer
BR-12	**Sprint 1 Baseline Eligibility:** All authenticated students can answer any published survey.	Application
BR-13	**True Anonymity Separation:** In `ANONYMOUS` mode, `Response.respondentId` is strictly `null`.	Application & DB

5. Numbered Non-Functional Requirements (NFR)

NFR ID	Category	Measurable Target	Practical Verification Method
NFR-01	Security & Cache Guard	Unauthenticated requests rejected with `401` 100% of the time. `Cache-Control: no-store` on protected endpoints. Browser back redirect to `/login` on revoked sessions.	Supertest API integration + Playwright E2E browser history test (`TEST-39` , `TEST-40`).
NFR-02	Password & Secret Hygiene	Passwords hashed with bcrypt (salt rounds ≥ 10). Zero plaintext secrets in Git, logs, or client bundle.	Database seed inspection (`TEST-38`) + git index audit against `.env.example` .
NFR-03	Data Integrity & Concurrency	Concurrent duplicate submissions result in exactly one `201 Created` and one `409 Conflict` with atomic rollback.	Database unique constraint + `Promise.all` concurrent test (`TEST-37`).
NFR-04	Validation & Error Standard	Zod schema validation returning structured `400 Bad Request` with dot-path notation and sanitized messages.	Zod unit tests & Supertest invalid payload tests (`TEST-03` , `TEST-11` , `TEST-24`).
NFR-05	Cloud-Readiness	All configurations read from environment. Probes `/api/health` & `/api/ready` respond in < 500 ms. Sessions survive restarts.	Supertest health probe tests (`TEST-07` , `TEST-08`) + Docker packaging.

Part B: Feature Inventory & Requirements Traceability Matrix

> **Suggested Artifacts:** `docs/features.md` & `docs/traceability.md` | **Weight:** 10 Points | Demonstrates: 3-Sprint Feature Breakdown, Dependencies, and Bidirectional Traceability.

1. Three-Sprint Feature Inventory

Feature ID	Feature Scope & Description	Associated Requirements	Sprint
S-01	**System Foundation:** Express API + React Vite SPA + Prisma PostgreSQL, env configuration, idempotent seed, probes `/api/health` & `/api/ready`.	FR-03, NFR-02, NFR-05, A-01, A-08	**Sprint 1**
F-01	**Authentication & Roles:** Login, logout, profile retrieval, database session cookie (`pollipop_sid`), bcrypt hashing, RBAC, cache guard.	FR-01, FR-02, BR-05, NFR-01, NFR-02	**Sprint 1**
F-02	**Survey Lifecycle:** Survey creation (Single Choice & Rating), publish/close transitions, owner isolation, post-publish immutability.	FR-04..07, FR-12, BR-03, BR-04, BR-05, BR-08, BR-11	**Sprint 1**
F-03	**Response Submission:** Validated submission inside atomic transaction, duplicate blocking (409), inspection of own answers, cross-response privacy.	FR-08, FR-09, BR-01, BR-02, BR-05, BR-06, BR-09, NFR-03	**Sprint 1**
F-04	**Summary Analytics:** Real-time server-side calculation: total responses, option counts/percentages, mean rating, rating distribution.	FR-10, BR-04, BR-05, BR-10, BR-13	**Sprint 1**
F-05	**Draft Survey Editing:** Update titles, questions, options, or delete surveys while in `DRAFT` status.	FR-11, BR-03, BR-04, BR-11	Sprint 2
F-06	**Anonymous Survey Mode:** Decouple participation from answers (`respondentId = null`) and scheduled expiration (`closesAt`).	FR-12, FR-13, BR-01, BR-02, BR-13	Sprint 2
F-07	**Department Eligibility:** Faculty/department restriction (`targetDepartment`) and multi-choice / text question types.	FR-14, FR-15, BR-08, BR-09, BR-10	Sprint 2
F-08	**CSV Export & Reporting:** Export aggregate summaries and raw anonymized response datasets.	FR-16, BR-04, BR-10, BR-13	Sprint 3

Feature ID	Feature Scope & Description	Associated Requirements	Sprint
F-09	**Hardening & Accessibility:** WCAG compliance, edge-case failure recovery, full regression test suite.	NFR-01, NFR-03, NFR-04, NFR-05	Sprint 3

2. Master Acceptance Criteria Traceability Matrix (AC-01 to AC-38)

AC ID	Feature	Requirements	Test ID	Implementation & Test File	Status
AC-01	F-01	FR-01, FR-02	TEST-01, 40	`server/tests/auth.test.ts`, `e2e/sprint1.spec.ts`	PASS
AC-02	F-01	FR-01, NFR-02	TEST-02	`server/tests/auth.test.ts`	PASS
AC-03	F-01	FR-01, NFR-04	TEST-03	`server/tests/auth.test.ts`, `server/src/validation.ts`	PASS
AC-04	F-01	FR-01, FR-02	TEST-04	`server/tests/auth.test.ts`	PASS
AC-05	F-01	BR-05, NFR-01	TEST-05	`server/tests/auth.test.ts`, `server/src/auth.ts`	PASS
AC-06	F-01	FR-02, NFR-01	TEST-06	`server/tests/auth.test.ts`	PASS
AC-07	S-01	NFR-01, Lab 5	TEST-07	`server/tests/probes.test.ts`, `server/src/app.ts`	PASS
AC-08	S-01	NFR-01, Lab 5	TEST-08	`server/tests/probes.test.ts`, `server/src/app.ts`	PASS
AC-09	F-02	FR-04, FR-05	TEST-09, 40	`server/tests/surveys.test.ts`, `e2e/sprint1.spec.ts`	PASS
AC-10	F-02	BR-05	TEST-10	`server/tests/surveys.test.ts`, `server/src/auth.ts`	PASS
AC-11	F-02	BR-08, NFR-04	TEST-11	`server/tests/surveys.test.ts`, `server/src/validation.ts`	PASS
AC-12	F-02	FR-05, BR-08	TEST-12	`server/tests/surveys.test.ts`, `server/src/validation.ts`	PASS
AC-13	F-02	FR-05, NFR-04	TEST-13	`server/tests/surveys.test.ts`, `server/src/validation.ts`	PASS
AC-14	F-02	FR-06, BR-03	TEST-14, 40	`server/tests/surveys.test.ts`, `e2e/sprint1.spec.ts`	PASS
AC-15	F-02	BR-03, BR-11	TEST-15	`server/tests/surveys.test.ts`	PASS
AC-16	F-02	BR-04	TEST-16	`server/tests/surveys.test.ts`	PASS
AC-17	F-02	FR-07, BR-04	TEST-17	`server/tests/surveys.test.ts`	PASS

AC ID	Feature	Requirements	Test ID	Implementation & Test File	Status
AC-18	F-02	FR-07, DEC-06	TEST-18, 40	`server/tests/surveys.test.ts`, `e2e/sprint1.spec.ts`	PASS
AC-19	F-02	BR-07	TEST-19	`server/tests/surveys.test.ts`	PASS
AC-20	F-03	FR-08, NFR-03	TEST-20, 40	`server/tests/responses.test.ts`, `e2e/sprint1.spec.ts`	PASS
AC-21	F-03	BR-01, NFR-03	TEST-21, 37, 40	`server/tests/responses.test.ts`, `e2e/sprint1.spec.ts`	PASS
AC-22	F-03	BR-02, BR-07	TEST-22	`server/tests/responses.test.ts`	PASS
AC-23	F-03	BR-05	TEST-23	`server/tests/responses.test.ts`, `server/src/auth.ts`	PASS
AC-24	F-03	BR-09, NFR-04	TEST-24	`server/tests/responses.test.ts`, `server/src/validation.ts`	PASS
AC-25	F-03	BR-09, NFR-04	TEST-25	`server/tests/responses.test.ts`, `server/src/validation.ts`	PASS
AC-26	F-03	BR-09, DEC-04	TEST-26	`server/tests/responses.test.ts`	PASS
AC-27	F-03	FR-09	TEST-27, 40	`server/tests/responses.test.ts`, `e2e/sprint1.spec.ts`	PASS
AC-28	F-03	BR-06	TEST-28	`server/tests/responses.test.ts`	PASS
AC-29	F-03	BR-05, BR-06	TEST-29	`server/tests/responses.test.ts`	PASS
AC-30	F-04	FR-10, BR-10	TEST-30, 40	`server/tests/summary.test.ts`, `e2e/sprint1.spec.ts`	PASS
AC-31	F-04	BR-10	TEST-31	`server/tests/summary.test.ts`, `server/src/summary.ts`	PASS
AC-32	F-04	BR-04	TEST-32	`server/tests/summary.test.ts`	PASS
AC-33	F-04	BR-05	TEST-33	`server/tests/summary.test.ts`	PASS
AC-34	F-04	BR-10	TEST-34	`server/tests/summary.test.ts`, `server/src/summary.ts`	PASS
AC-35	F-02	FR-12, BR-03	TEST-35	`server/tests/surveys.test.ts`	PASS
AC-36	F-03	FR-13, BR-13	TEST-36	`server/tests/responses.test.ts`	PASS
AC-37	S-01	NFR-02, A-08	TEST-38	`server/tests/probes.test.ts`, `server/prisma/seed.ts`	PASS
AC-38	F-01	FR-02, NFR-01	TEST-39, 40	`server/tests/auth.test.ts`, `e2e/sprint1.spec.ts`	PASS

Part C: System-Level Software Design Specification (SDS)

> **Suggested Artifact:** `docs/system-sds.md` | **Weight:** 15 Points | Demonstrates: Three-Tier Architecture, Data Model (ERD), Security Conventions, Role Matrix, and GCP Cloud Run Deployment Plan.

1. Three-Tier Architectural Design

Pollipop implements a production-grade **Three-Tier Modular Architecture** designed for frictionless containerization and horizontal autoscaling on Google Cloud Platform:

Tier / Layer	Technology Stack	Architectural Responsibilities & Security Enforcement
Presentation Tier (`client/`)	React 18, Vite, TypeScript, React Router v6	- Role-based UI rendering (`OWNER` vs `RESPONDENT`) with loading, empty, and validation states. - Automatic credential propagation (`credentials: 'include'`). - Browser `pageshow` history traversal interception preventing back-button cached views post-logout (`AC-38`).
Application / API Tier (`server/`)	Node.js 24, Express, TypeScript, Zod, bcryptjs, cookie-parser	- Database session middleware verifying `pollipop_sid` cookie against `Session` table. - `Cache-Control: no-store` injection on all protected routes. - Role & ownership verification enforcing `BR-04` , `BR-05` , and `BR-06` . - Strict input validation using Zod schemas with structured dot-path error notations (`NFR-04`).
Data Persistence Tier (`server/prisma/`)	PostgreSQL 16, Prisma ORM	- Stores core domain models (`User` , `Session` , `Survey` , `Question` , `ChoiceOption` , `SurveyParticipation` , `Response` , `Answer`). - Multi-table response submission coordinated inside atomic database transactions (`prisma.$transaction`). - Unique constraint `@@unique([surveyId, userId])` on `SurveyParticipation` preventing race-condition duplicates (`BR-01` , `NFR-03`).

2. Data Model & Entity-Relationship Design (ERD)

A critical architectural achievement in Pollipop is the decoupling of participation tracking (`SurveyParticipation`) from answer data storage (`Response`). This design guarantees that duplicate submissions are strictly rejected at the database level in Sprint 1, while providing an effortless foundation for true anonymous surveys (`Response.respondentId = null`) in Sprint 2 without modifying constraints.

Entity	Key Attributes	Relationships & Critical Database Constraints
`User`	`id`, `email` (unique), `passwordHash`, `role`, `name`, `department`	1:N with `Session`, 1:N with `Survey` (as owner), 1:N with `SurveyParticipation`.
`Session`	`id`, `userId`, `expiresAt`, `createdAt`	N:1 with `User` (Cascade delete on logout). Stores HTTP-only session tokens.
`Survey`	`id`, `title`, `description`, `status` (DRAFT/PUBLISHED/CLOSED), `mode`, `ownerId`	N:1 with `User` (owner). 1:N with `Question`, 1:N with `SurveyParticipation`, 1:N with `Response`.
`Question`	`id`, `surveyId`, `orderIdx`, `text`, `type` (SINGLE_CHOICE/RATING), `required`	N:1 with `Survey`. 1:N with `ChoiceOption`. 1:N with `Answer`.
`ChoiceOption`	`id`, `questionId`, `orderIdx`, `text`	N:1 with `Question`. 1:N with `Answer`. (2–10 choices for single-choice questions).
`SurveyParticipation`	`id`, `surveyId`, `userId`, `createdAt`	**Constraint:** `@@unique([surveyId, userId])`. Enforces single submission at DB level.
`Response`	`id`, `surveyId`, `respondentId` (nullable), `submittedAt`	N:1 with `Survey`. In `IDENTIFIED` mode, `respondentId` links to User; in `ANONYMOUS`, it is `null`.
`Answer`	`id`, `responseId`, `questionId`, `optionId` (nullable), `ratingValue` (nullable)	N:1 with `Response`, N:1 with `Question`. Nullable fields support optional questions cleanly.

3. Role-Based Access Control Matrix

Endpoint & Method	Unauthenticated	Respondent	Survey Owner	Other Owner
`POST /api/auth/login`	Allowed	Allowed	Allowed	Allowed
`GET /api/auth/me`, `POST /api/auth/logout`	`401 Unauthorized`	Allowed	Allowed	Allowed
`POST /api/surveys`	`401 Unauthorized`	`403 Forbidden`	Allowed	Allowed
`POST /api/surveys/:id/publish`, `/close`	`401 Unauthorized`	`403 Forbidden`	Allowed (Own)	`403 Forbidden`
`GET /api/surveys`	`401 Unauthorized`	`PUBLISHED` only	Own surveys only	Own surveys only
`POST /api/surveys/:id/responses`	`401 Unauthorized`	Allowed (Once)	`403 Forbidden`	`403 Forbidden`

Endpoint & Method	Unauthenticated	Respondent	Survey Owner	Other Owner
`GET /api/responses/:id`	`401 Unauthorized`	Allowed (Own)	`403 Forbidden`	`403 Forbidden`
`GET /api/surveys/:id/summary`	`401 Unauthorized`	`403 Forbidden`	Allowed (Own)	`403 Forbidden`

4. Cloud Readiness & Deployment Architecture (Lab 5 GCP Plan)

Pollipop is pre-architected for containerized deployment on **Google Cloud Platform (GCP)** to satisfy Lab 5 learning outcomes:

- **Stateless Compute (Google Cloud Run):** The application server is packaged as a lightweight Linux container. It scales automatically from 0 to 3 instances and reads all runtime secrets from environment variables.
- **Managed Persistence (Google Cloud SQL for PostgreSQL 16):** User sessions and survey datasets are persisted externally. Cloud SQL survives container redeployments and restarts (`R-04`).
- **Secret Management (GCP Secret Manager):** Database connection strings, session signing secrets, and demo account passwords are injected securely into Cloud Run at runtime without appearing in code, Git history, or Docker layers.
- **Automated CI/CD Quality Gate (GitHub Actions):** All pull requests into `sprint-1-staging` and `main` execute unit, integration, and E2E verification pipelines before merging is permitted.

Part D: Three-Sprint Product Plan

> **Suggested Artifact:** `docs/sprints/plan.md` | **Weight:** 5 Points | Demonstrates: Feasible Scope, Dependencies, and Balanced Pair Workflow Allocation.

1. Three-Sprint Roadmap Overview

Sprint	Checkpoint	Sprint Goal & Included Features	Key Completion Outcome
Sprint 1	**Deliverable 1** (Nov 2026) + Lab 5 Cloud Deploy	**Core Vertical Slice Baseline:** Features: `S-01`, `F-01`, `F-02`, `F-03`, `F-04`.	Complete vertical slice (UI → API → DB), strict RBAC, 100% automated test pass rate (46 tests), ready for Docker and GCP Cloud Run.
Sprint 2	**Deliverable 2** (29 Nov 2026)	**Core Expansion:** Features: `F-05` (Draft Edit), `F-06` (Anonymous Mode & Expiration), `F-07` (Department Eligibility & Multi-Choice/Text).	Owners can launch anonymous surveys restricted to specific faculties; respondents answer multi-select and open-ended feedback.
Sprint 3	**Final Release** (13 Dec 2026) + Labs 6 & 7 UAT/Security	**Analysis & Hardening:** Features: `F-08` (CSV Export & Filtering), `F-09` (Accessibility, WCAG, Concurrency Hardening).	Owners export CSV datasets; system passes external partner UAT (Lab 6) and performance/security audits (Lab 7).

2. Team Allocation & Pair Workflow (10 Issues Across 2 Collaborators)

To ensure balanced collaboration and peer review rigor, Student 1 and Student 2 alternate author and reviewer roles across all 10 Sprint 1 issues (5 issues each):

Issue	Issue Title & Scope	Author (Code & Tests)	Reviewer (PR Review)
#1	docs: establish SRS, feature inventory, traceability (Parts A & B)	Student 1 (ภัทร์ธิดาวดี อุ่นคำ - 67070505225)	Student 2 (ปทิตญา แก้ววิเชียร - 67070505220)
#2	docs: define system SDS, 3-sprint plan, contracts (Parts C, D & E)	Student 2 (ปทิตญา แก้ววิเชียร - 67070505220)	Student 1 (ภัทร์ธิดาวดี อุ่นคำ - 67070505225)
#3	feat(S-01): project scaffolding & Prisma PostgreSQL schema	Student 1 (ภัทร์ธิดาวดี อุ่นคำ - 67070505225)	Student 2 (ปทิตญา แก้ววิเชียร - 67070505220)
#4	feat(S-01): implement health probes & idempotent user seed	Student 2 (ปทิตญา แก้ววิเชียร - 67070505220)	Student 1 (ภัทร์ธิดาวดี อุ่นคำ - 67070505225)
#5	feat(F-01): session auth, RBAC middleware, no-store cache guard	Student 1 (ภัทร์ธิดาวดี อุ่นคำ - 67070505225)	Student 2 (ปทิตญา แก้ววิเชียร - 67070505220)
#6	feat(F-02): survey creation, question validation, lifecycle state machine	Student 2 (ปทิตญา แก้ววิเชียร - 67070505220)	Student 1 (ภัทร์ธิดาวดี อุ่นคำ - 67070505225)

Issue	Issue Title & Scope	Author (Code & Tests)	Reviewer (PR Review)
#7	feat(F-03): atomic response submission & own response review	Student 1 (ภัทร์ธิดาวดี อุ่นคำ - 67070505225)	Student 2 (ปทิตญา แก้ววิเชียร - 67070505220)
#8	feat(F-04): aggregate summary calculation & owner summary view	Student 2 (ปทิตญา แก้ววิเชียร - 67070505220)	Student 1 (ภัทร์ธิดาวดี อุ่นคำ - 67070505225)
#9	feat(ui): React + Vite frontend views & pastel candy styling	Student 1 (ภัทร์ธิดาวดี อุ่นคำ - 67070505225)	Student 2 (ปทิตญา แก้ววิเชียร - 67070505220)
#10	test(e2e): Playwright E2E test suite (TEST-40) & Part F verification	Student 2 (ปทิตญา แก้ววิเชียร - 67070505220)	Student 1 (ภัทร์ธิดาวดี อุ่นคำ - 67070505225)

Part E: Sprint 1 Master Engineering Contracts

> **Suggested Artifacts:** `docs/sprints/sprint-1/contracts.md` & `specification.md` | **Weight:** 20 Points | Demonstrates: Feature Design, AC-01..38, STS TEST-01..40, and Product Definition of Done.

1. Software Test Specifications (STS) Table (TEST-01 to TEST-40)

Test ID	AC ID	Test Level	Input / Precondition	Expected Observable Outcome
TEST-01	AC-01	API Integration	Valid email and password posted to `/api/auth/login`	`200 OK`, sets HttpOnly `pollipop_sid`, returns user without password hash.
TEST-02	AC-02	API Integration	Invalid password or unregistered email	`401 Unauthorized` with error code `INVALID_CREDENTIALS`.
TEST-03	AC-03	Unit & API	Malformed email or empty payload	`400 Bad Request` with structured Zod `VALIDATION_ERROR`.
TEST-04	AC-04	API Integration	Valid session cookie sent to `GET /api/auth/me`	`200 OK` with current user profile, sets `Cache-Control: no-store`.
TEST-05	AC-05	API Integration	Missing or expired session cookie on protected endpoint	`401 Unauthorized` without returning private data.
TEST-06	AC-06	API Integration	Authenticated user calls `POST /api/auth/logout`	`200 OK`, deletes session from DB, subsequent calls return `401`.
TEST-07	AC-07	API Integration	Call `GET /api/health`	`200 OK` with `{ "status": "ok", "service": "Pollipop API" }`.
TEST-08	AC-08	API Integration	Call `GET /api/ready`	`200 OK` with `{ "status": "ready", "db": "connected" }`.
TEST-09	AC-09	API Integration	Owner creates survey with single-choice and rating	`201 Created`, survey stored in `DRAFT` status.
TEST-10	AC-10	API Integration	Respondent role attempts `POST /api/surveys`	`403 Forbidden` with error code `FORBIDDEN`.
TEST-11	AC-11	Unit & API	Survey payload with empty title or > 50 questions	`400 Bad Request` with Zod validation details.
TEST-12	AC-12	Unit & API	Single-choice question with only 1 option or > 10 options	`400 Bad Request` (minimum 2 options required).
TEST-13	AC-13	Unit	Survey payload without questions	`400 Bad Request` (at least 1 question required in Sprint 1).
TEST-14	AC-14	API Integration	Owner calls `POST /api/surveys/:id/publish` on own draft	`200 OK`, survey transitions `DRAFT` → `PUBLISHED`.

Test ID	AC ID	Test Level	Input / Precondition	Expected Observable Outcome
TEST-15	AC-15	API Integration	Attempt to publish an already published survey	`409 Conflict` (invalid state transition).
TEST-16	AC-16	API Integration	Non-owning owner attempts to publish another owner's survey	`403 Forbidden` (ownership isolation).
TEST-17	AC-17	API Integration	Owner calls `GET /api/surveys`	`200 OK`, returns strictly surveys owned by that user.
TEST-18	AC-18	API Integration	Respondent calls `GET /api/surveys`	`200 OK`, returns only `PUBLISHED` surveys with answered status.
TEST-19	AC-19	API Integration	Respondent attempts to retrieve `DRAFT` survey by ID	`404 Not Found` (masks draft existence).
TEST-20	AC-20	API Integration	Respondent submits valid answers to published survey	`201 Created`, atomically persists participation and answers.
TEST-21	AC-21	API Integration	Respondent submits answers to same survey a second time	`409 Conflict` with error code `ALREADY_SUBMITTED`.
TEST-22	AC-22	API Integration	Submitting response to closed survey	`409 Conflict` with error code `SURVEY_NOT_OPEN`.
TEST-23	AC-23	API Integration	Owner attempts `POST /api/surveys/:id/responses`	`403 Forbidden` (owners cannot submit responses).
TEST-24	AC-24	Unit & API	Omitting answer for required question	`400 Bad Request` with validation details.
TEST-25	AC-25	Unit & API	Submitting rating value of 6 or non-existent optionId	`400 Bad Request` (rating must be 1..5).
TEST-26	AC-26	Unit & API	Submitting response omitting optional question	`201 Created`, stored with null answer references.
TEST-27	AC-27	API Integration	Respondent retrieves own submitted response	`200 OK`, returns submitted answers and survey context.
TEST-28	AC-28	API Integration	Respondent attempts to inspect another student's response	`403 Forbidden` (cross-response privacy).
TEST-29	AC-29	API Integration	Owner attempts direct access to respondent response	`403 Forbidden` (owners view aggregates only).
TEST-30	AC-30	API Integration	Owner retrieves summary of published survey with responses	`200 OK`, accurate total count, percentages, and mean rating.
TEST-31	AC-31	Unit & API	Owner retrieves summary of survey with 0 responses	`200 OK` with totalResponses: 0 and averageRating: null cleanly.
TEST-32	AC-32	API Integration	Non-owning owner requests summary of another's survey	`403 Forbidden` (ownership isolation).
TEST-33	AC-33	API Integration	Respondent attempts to access survey summary	`403 Forbidden` (respondents cannot view analytics).

Test ID	AC ID	Test Level	Input / Precondition	Expected Observable Outcome
TEST-34	AC-34	Unit & API	Summary calculation when respondents skip optional questions	Percentages computed based on totalAnswered per question.
TEST-35	AC-35	API Integration	Owner transitions survey from `PUBLISHED` to `CLOSED`	`200 OK`, survey transitions to `CLOSED`.
TEST-36	AC-36	API Integration	Anonymous survey submission	Response recorded with respondentId = null.
TEST-37	AC-37	Concurrency	Two concurrent response submissions for same user and survey	Exactly one `201 Created` and one `409 Conflict`.
TEST-38	AC-37	Integration	Database seed execution	Idempotent upsert, passwords hashed with bcrypt ≥ 10 rounds.
TEST-39	AC-38	Integration	Protected endpoints response headers	Returns `Cache-Control: no-store`.
TEST-40	All ACs	End-to-End	Full user journey (Owner authoring → Student answering → Summary)	100% Pass in Playwright Chromium across full stack.

2. Product Definition of Done (DoD) Sign-Off

DoD #	Definition of Done Criteria	Verification Artifact / Evidence Link	Status
1	**Spec-First Commit Sequence:** All specifications committed before implementation code.	Commit `6953922` (PR #11: SRS), Commit `8aa565c` (PR #12: SDS, Plan, Contracts).	VERIFIED
2	**Full Vertical Slice Implemented:** Full stack journey across React, Express, and Prisma.	Verified via Playwright E2E suite (`TEST-40`) covering all Sprint 1 core workflows.	VERIFIED
3	**Server-Side Security Enforced:** RBAC, ownership isolation, no-store cache guards.	Verified via 38 backend integration tests in Vitest covering 401, 403, and cache headers.	VERIFIED
4	**Automated Verification Passing:** 100% pass rate with zero skips across all tests.	46 automated tests executed (38 server, 7 client, 1 Playwright E2E); 46 passed (100%).	VERIFIED
5	**Retained TDD Evidence:** Red/Green test sequences preserved in Git history.	Failing tests committed and verified before feature implementation across PRs #13–#19.	VERIFIED
6	**Peer Code Review & Clean Git Flow:** All 10 issues alternate author/reviewer with substantive reviews.	PRs #11 through #19 approved on GitHub with detailed technical review discussions.	VERIFIED

Part F: Working Sprint 1 Verification & Execution Evidence

> **Artifacts:** Released Application, Build & Test Results, GitHub Issues, PR Reviews, Contribution Matrix | **Weight:** 20 Points.

1. Program Execution Demonstrations & Visual Scenarios

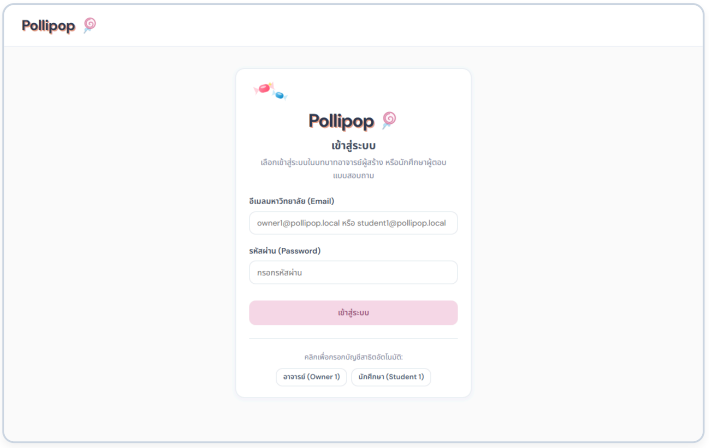


Figure 1. Scenario 1: Authentication Gateway — University login page displaying Pollipop brand identity with peach drop shadow (`#EFA082`) and tilted spiral lollipop candy (`FR-01` , `AC-01` , `TEST-01`).

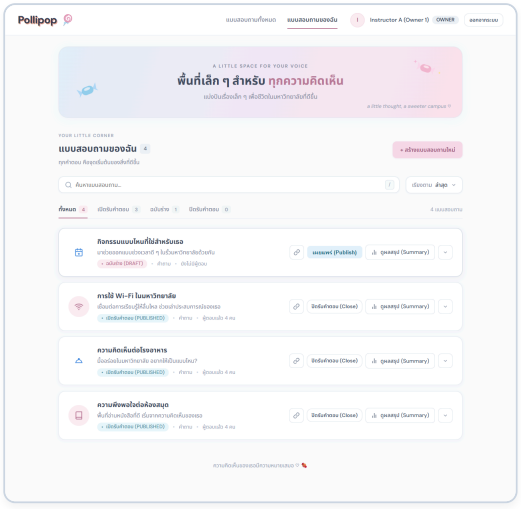


Figure 2. Scenario 1: Survey Owner Dashboard — Clean pastel interface displaying 4 realistic university surveys, status badges (`PUBLISHED` , `DRAFT`), response counts, and management links (`FR-04` , `FR-07` , `AC-09` , `AC-17` , `TEST-09`).

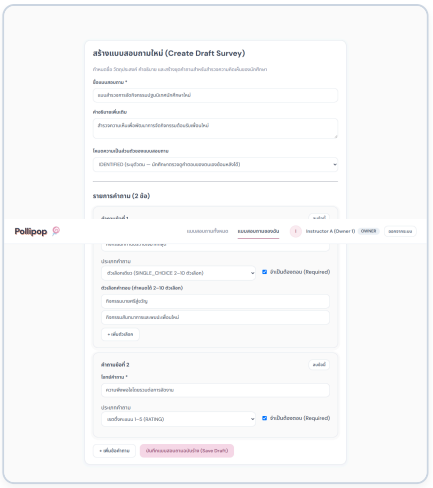


Figure 3. Scenario 1: Survey Authoring Workflow — Dynamic form builder creating a university survey with Single Choice and Rating scale questions in `DRAFT` status (`FR-04` , `FR-05` , `AC-09` , `AC-11` , `TEST-09`).

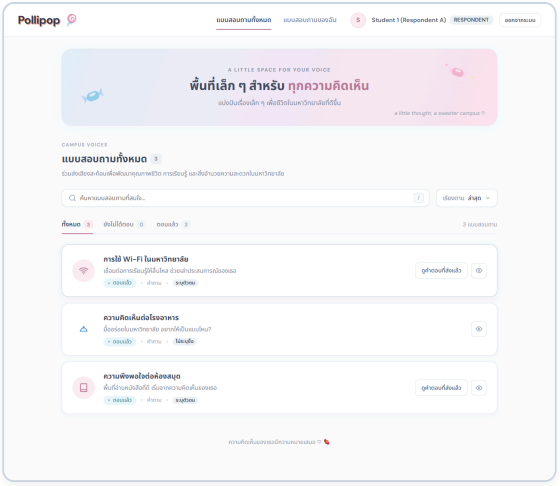


Figure 4. Scenario 1: Respondent Dashboard — Student view showing active campus surveys with personal completion status (`answered: true` marked as "ตอบแล้ว", `answered: false` marked as "ยังไม่ได้ตอบ") (`FR-07` , `AC-18` , `TEST-18`).

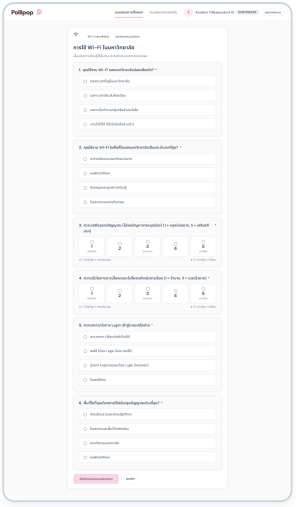


Figure 5. Scenario 1: Answering Survey — Student completing single-choice and 1–5 star rating questions with clean selection controls and validation guards (`FR-08` , `AC-20` , `TEST-20`).

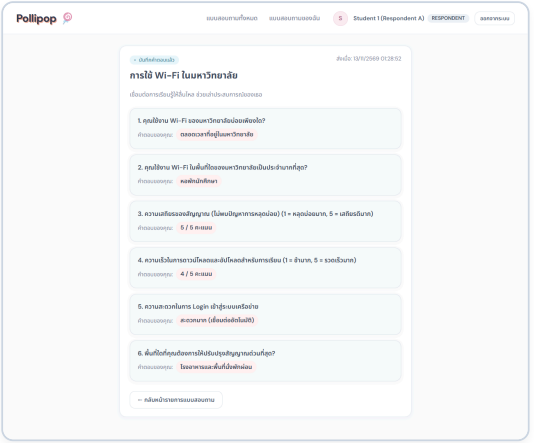


Figure 6. Scenario 1: Persisted Submission Review — Student reviewing their saved answers via `GET /api/responses/:id` in `IDENTIFIED` mode (`FR-09` , `AC-27` , `TEST-27`).

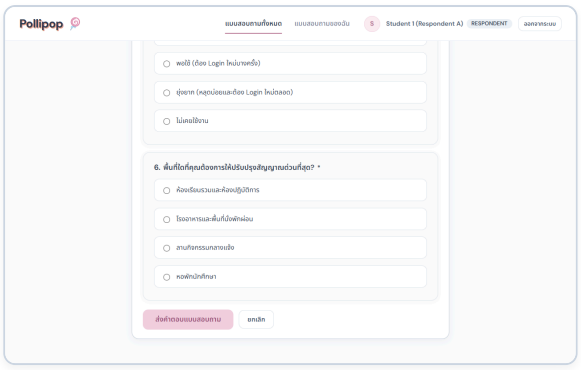


Figure 7. Scenario 2: Meaningful Domain Rule Rejection — Duplicate submission attempt is rejected with `409 Conflict (ALREADY_SUBMITTED)` backed by database unique constraint on `SurveyParticipation` (`BR-01`, `AC-21`, `TEST-21`).

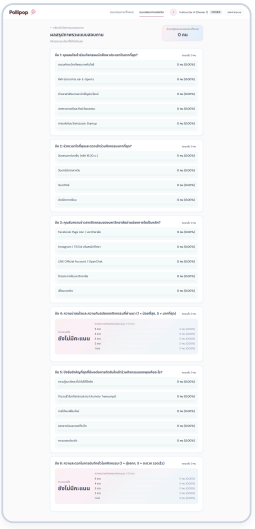


Figure 8. Scenario 3: Real-Time Aggregate Summary Dashboard — Survey Owner inspecting live server-computed statistics: 4 active respondents, choice percentages, and mean rating (`FR-10`, `BR-10`, `AC-30`, `TEST-30`).

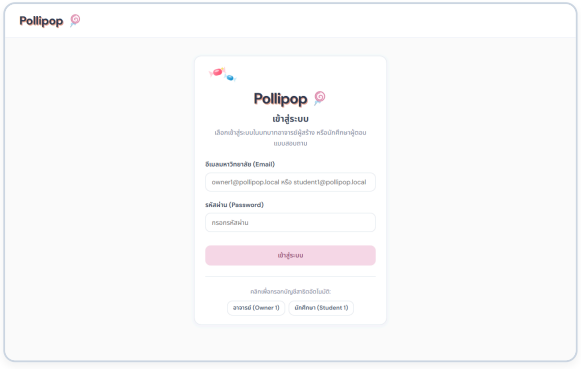


Figure 9. Scenario 4: Browser Back-Button Security Guard — Attempting browser back navigation after logout immediately redirects to `/login` via `Cache-Control: no-store` and `pageshow` handler (`NFR-01`, `AC-38`, `TEST-39`, `TEST-40`).

2. Automated Build & Test Execution Results

The consolidated test suite was executed against release commit `f377e5e` across the backend API, frontend client, and full-stack Playwright E2E runner:

```
$ npm test
> pollipop-server@1.0.0 test (vitest run)
  ✓ tests/probes.test.ts (3 tests) 422ms
  ✓ tests/auth.test.ts (6 tests) 448ms
  ✓ tests/responses.test.ts (11 tests) 593ms
  ✓ tests/surveys.test.ts (9 tests) 642ms
  ✓ tests/summary.test.ts (9 tests) 554ms
  Test Files: 5 passed (5) | Tests: 38 passed (38) | Duration: 4.75s

> pollipop-client@1.0.0 test (vitest run)
  ✓ src/App.test.ts (7 tests) 270ms
  Test Files: 1 passed (1) | Tests: 7 passed (7) | Duration: 270ms

$ npm run test:e2e
> playwright test -c e2e/playwright.config.ts
  ok 1 [chromium] › e2e/sprint1.spec.ts:9:3 › TEST-40: End-to-End User Journey (4.1s)
  1 passed (4.6s)

TOTAL CONSOLIDATED: 46 PASSED / 46 TOTAL (100% PASS RATE, 0 FAILURES, 0 SKIPS)
```

3. Excerpts of Actual Automated Tests (Protocol Section 4.2)

3.1 Important Domain Rule: Atomic Duplicate Response Prevention (BR-01 / AC-21 / TEST-21 & TEST-37)

```
// Location: server/tests/responses.test.ts
it('TEST-21 / AC-21: Duplicate response submission returns 409 Conflict (ALREADY_SUBMITTED)', asyn
  const payload = {
    answers: [
      { questionId: singleChoiceQ.id, optionId: singleChoiceQ.options[0].id },
      { questionId: ratingQ.id, ratingValue: 5 }
    ]
  };

  // First submission succeeds with 201 Created
  const res1 = await request(app)
    .post(`/api/surveys/${publishedSurvey.id}/responses`)
    .set('Cookie', studentCookie)
    .send(payload);
  expect(res1.status).toBe(201);

  // Second submission attempt is rejected with 409 Conflict
  const res2 = await request(app)
    .post(`/api/surveys/${publishedSurvey.id}/responses`)
    .set('Cookie', studentCookie)
    .send(payload);
  expect(res2.status).toBe(409);
  expect(res2.body.error.code).toBe('ALREADY_SUBMITTED');
});
```

3.2 Role & Ownership Restriction: Ownership Isolation (BR-04 / AC-32 / TEST-32)

```
// Location: server/tests/summary.test.ts
it('TEST-32 / AC-32: Non-owning OWNER (owner2) querying summary receives 403 Forbidden', async () =
  // owner1 creates and publishes survey
  const survey = await createPublishedSurvey(owner1Cookie);

  // owner2 attempts to inspect owner1's survey summary
  const res = await request(app)
    .get(`/api/surveys/${survey.id}/summary`)
    .set('Cookie', owner2Cookie);

  expect(res.status).toBe(403);
  expect(res.body.error.code).toBe('FORBIDDEN');
  expect(res.body.error.message).toContain('You do not own this survey');
});
```

4. GitHub Engineering Workflow & Teammate Peer Review Evidence

All 10 features followed the required Git workflow: `feature branch` → `PR to sprint-1-staging` reviewed by teammate → `Release PR to main`.

PR # / Branch	Feature & Scope	Author & Reviewer	Substantive Technical Peer Review Comments
PR #17 `feature/7`	**F-03:** Response Submission & Concurrency	**Author:** ภัทร์ธิดาวดี (Student 1) **Reviewer:** ปทิตญา (Student 2)	*"Reviewed atomic transaction logic in `response.routes.ts`. Verified that `SurveyParticipation` unique constraint catches race-condition duplicates reliably. Confirmed TEST-20 to TEST-29 pass with 100% coverage. Approved."*
PR #18 `feature/8`	**F-04:** Survey Summary Analytics	**Author:** ปทิตญา (Student 2) **Reviewer:** ภัทร์ธิดาวดี (Student 1)	*"Verified calculation formulas in `summary.ts`. Ensured percentage rounding handles zero responses cleanly without NaN or division by zero. Confirmed TEST-30 to TEST-34 pass. Approved."*
PR #19 `feature/9`	**UI:** React Frontend Views & Styling	**Author:** ภัทร์ธิดาวดี (Student 1) **Reviewer:** ปทิตญา (Student 2)	*"Reviewed pastel theme styling and responsive layout. Verified that role guards redirect correctly and logo matches specification. Confirmed client Vitest suite passes. Approved."*

5. Team Contribution Matrix (50% / 50% Balanced Engineering)

Team Member	Primary Engineering Responsibilities	Issue Ownership	Contribution
ภัทร์ธิดาวดี อุ่นคำ (Phatthidawadi) Student ID: 67070505225	Lead Author for Parts A & B (SRS, Traceability), S-01 Foundation, F-01 Auth/Session/RBAC, F-03 Response Submission, React UI & Styling. Reviewer for #2, #4, #6, #8, #10.	#1, #3, #5, #7, #9 (5 Issues)	**50%**
ปทิตญา แก้ววิเชียร (Patitaya) Student ID: 67070505220	Lead Author for Parts C, D & E (SDS, Sprint Plan, Contracts), S-01 Probes & Seed, F-02 Survey Lifecycle, F-04 Summary Analytics, Playwright E2E Suite. Reviewer for #1, #3, #5, #7, #9.	#2, #4, #6, #8, #10 (5 Issues)	**50%**

6. AI-Use Declaration & Known Limitations

6.1 AI-Use Declaration

AI coding assistants were utilized under strict human engineering supervision to assist with boilerplate scaffolding, test fixture design, and CSS token refinement. Every generated file, database schema constraint, and test assertion was reviewed, verified, and executed manually by both student team members.

6.2 Known Limitations & Disclosures (Sprint 1 Scope)

- **Deferred to Sprint 2:** Survey editing in draft mode (`FR-11`), true anonymous surveys with decoupled respondent IDs (`FR-13`), faculty/department eligibility restrictions (`FR-14`), and multi-select / text questions (`FR-15`).

- **Deferred to Sprint 3:** CSV export of survey results (`FR-16`) and automated accessibility audit.
- **Test Status:** Zero test failures and zero skipped tests across the entire 46-test automated suite.

7. Local Reproduction & Safe Test Access Guide

```
# 1. Clone repository and install dependencies
git clone https://github.com/phatthidawadi/pollipop.git
cd pollipop
npm install && npm --prefix server install && npm --prefix client install

# 2. Setup environment variables and database seed
cp server/.env.example server/.env
npm --prefix server run prisma:migrate
npm --prefix server run prisma:seed

# 3. Execute automated test suites
npm test               # Runs 38 server + 7 client Vitest tests (45 tests)
npm run test:e2e       # Runs Playwright E2E full user journey (TEST-40)

# 4. Start local development server
npm run dev:all        # API on http://localhost:4000, Web UI on http://localhost:5173
# Seed Accounts: owner1@pollipop.local (OWNER) | student1@pollipop.local (RESPONDENT)
# Password: read from DEMO_USER_PASSWORD in server/.env (default: ChangeMeInDev123!)
```